

Password Policy Template

Establish robust password governance across your organisation

1. Password Length Requirements

- > Standard user accounts: minimum 12 characters
- > Privileged / administrative accounts: minimum 16 characters
- > Service accounts: minimum 20 characters with regular rotation
- > Passphrases (3+ random words) encouraged over complex strings

2. Password Complexity

- > Must contain characters from at least 3 of 4 categories: uppercase, lowercase, digits, special characters
- > No more than 3 consecutive identical characters permitted
- > Common password dictionary check enforced at creation
- > Contextual checks: no usernames, company name, or personal info in password

3. Password Expiry & History

- > Standard accounts: password expires every 90 days
- > Privileged accounts: password expires every 60 days
- > Password history: 12 unique passwords remembered (cannot reuse)
- > Maximum password age enforced; grace period of 24 hours before lockout

4. Multi-Factor Authentication (MFA)

- > MFA mandatory for all administrative and remote-access accounts
- > MFA required for all external-facing systems and VPN access
- > Accepted factors: TOTP authenticator app, hardware token (FIDO2/WebAuthn), or biometrics
- > SMS-based OTP only permitted when hardware/software tokens unavailable

5. Account Lockout Policy

- > Lockout threshold: 5 failed login attempts within a 15-minute window
- > Lockout duration: 30 minutes (automatic unlock) or administrator override
- > Failed attempt counter resets after 30 minutes of inactivity
- > Account lockout events logged and reported to Security Operations

6. Shared & Generic Accounts

- > Shared accounts prohibited unless approved by Information Security
- > Generic accounts (e.g., root, admin) must have passwords stored in an enterprise password manager
- > Individual accountability via session logging and named audit trails
- > Shared account credentials rotated immediately upon membership change

7. Enforcement & Compliance

- > Password policy enforced via Group Policy Object (GPO) or equivalent IAM controls
- > Quarterly automated compliance scans; manual exceptions require CISO sign-off
- > Non-compliant accounts flagged and quarantined within 48 hours
- > Annual policy review; updates approved by the Security Steering Committee

Document Control

Policy Owner:

Chief Information Security Officer (CISO)

Effective Date:

Date of publication

Review Cycle:

Annual or upon significant infrastructure change

Classification:

Internal - Confidential